

[데이터거버넌스센터] 데이터거버넌스센터 운영 가이드라인



2026. 9. 30.

인제대학교 글로벌대학사업본부
[데이터거버넌스센터]

데이터거버넌스센터 운영 가이드라인(안)

I 총칙

□ 가이드라인 수립 배경

○ 데이터 중심 사회로의 전환과 데이터 활용 환경 변화

- 디지털 기술 발전과 함께 대학 및 공공기관을 둘러싼 데이터 활용 환경이 급격하게 변화하고 있음
- 행정 처리·단순 기록 중심으로 관리되던 데이터가 연구 경쟁력 강화, 정책 의사결정 지원, 산학협력 확대, 지역사회 기여 등 다양한 목적으로 적극 활용되고 있음
- 대학은 교육·연구·행정·산학협력 등 다양한 영역에서 방대한 데이터를 생성하며, 데이터는 보조 자료를 넘어 중요한 전략 자산으로 인식되고 있음
- 학사·연구·의료·보건·산학협력 데이터, 공공데이터 연계 정보 등 데이터 유형이 다양해지고 클라우드와 외부 플랫폼을 통한 저장·처리·공유가 보편화 됨
- 생성형 AI 등 인공지능 활용이 교육·연구·행정 전반으로 확산되면서 학습데이터 관리와 AI 결과물 관리가 새로운 과제로 대두됨
- 이러한 변화는 활용 가능성을 확대하는 동시에 데이터 오·남용, 개인정보 침해, 보안 사고 등 새로운 위험 요인도 증가시키고 있음
- 데이터 활용을 개별 부서·개인 판단에 맡기는 방식에서 벗어나 조직 차원의 통합적 관리 체계 마련이 필수적인 상황임

○ 대학 및 공공기관 데이터 관리 패러다임의 변화

- 과거 대학의 데이터 관리는 행정 효율성 확보를 위한 기록 관리 수준에 머물렀으며, 특정 부서·담당자 중심으로 관리되어 조직 차원의 통합 관리 체계는 미흡하였음
- 데이터가 대학의 전략적 자산으로 인식되면서 단편적 관리에서 전사적·통합적 관리 체계로의 전환이 요구되고 있음
- 대학은 공공성을 기반으로 운영되는 기관으로서 민간 기업보다 높은 수준의 데이터 책임성과 투명성을 요구받고 있음
- 학생, 교직원, 연구 참여자, 의료 서비스 이용자 등 다양한 이해관계자의 개인정보·민감정보를 대규모로 처리하므로 관리 실패가 사회적 문제로 확대될 가능성이 큼
- 데이터 활용 가능성을 확대하는 동시에 데이터 보호와 윤리적 사용을 균형 있게 관리할 수 있는 거버넌스 구조 구축이 필요함
- 데이터거버넌스센터는 대학 내 데이터 관리의 중심 조직으로서 정책 수립, 기준 마련, 관리·감독 기능을 수행하는 핵심 역할을 담당함

○ 데이터 관련 사고 증가와 사회적 신뢰 확보의 필요성

- 공공기관과 대학을 포함한 다양한 조직에서 개인정보 유출, 내부자에 의한 오·남용, 연구 데이터 관리 부실 사례가 지속적으로 발생하고 있음
- 2025년 이후 대형 통신사·카드사 해킹 등 대규모 유출 사고가 잇따르며 개인정보 보호법 개정(2026. 9. 11. 시행)으로 제재가 크게 강화됨
- 데이터 사고는 보안 문제를 넘어 기관에 대한 사회적 신뢰를 심각하게 훼손할 수 있으며, 대학의 신뢰 상실은 학생·연구자·지역사회 전반에 부정적 영향을 미침
- 체계적 기준 마련과 지속적인 점검·개선 활동은 선택이 아닌 필수 과제로 인식되고 있음
- 본 가이드라인은 데이터 관리 과정의 위험 요소를 사전에 식별·예방하는 기준을 제시하여 인제대학교의 데이터 관리 신뢰성을 강화하고자 함

○ 국내·외 데이터 규제 환경의 고도화

- 국내에서는 개인정보 보호법을 중심으로 공공데이터법, 데이터기본법, 신용정보법, 위치정보법, 인공지능기본법 등 다양한 법령이 데이터 수집·이용·제공을 규율하고 있음
- 2026년 개정 개인정보 보호법은 대표자를 최종 책임자로 명시하고, 과징금 상한을 전체 매출액 10%까지 상향하며, 유출 가능성 72시간 통지 제도를 도입함
- 국제적으로는 EU GDPR을 비롯해 EU AI Act, Data Act, 유럽보건데이터공간(EHDS) 규정 등 데이터·AI 규제가 강화되고 있음
- 데이터 국외 이전, 국제 공동연구, 글로벌 클라우드 서비스 이용과 관련된 요건도 점점 엄격해지고 있음
- GDPR 역외 적용 조항에 따라 국내 대학도 EU 거주자의 개인정보를 처리하는 경우 직접적인 법적 영향을 받을 수 있음
- 대학은 국내 법령뿐 아니라 국제 규제와의 정합성을 함께 검토해야 하며, 본 가이드라인은 이를 종합 반영하여 안정적인 데이터 활용 전략 수립을 지원함

□ 목적 및 필요성

○ 데이터 거버넌스 체계 구축의 목적

- 인제대학교 내 데이터 수집·이용·관리 전반에 걸쳐 통합적이고 일관된 데이터 거버넌스 체계를 구축함

- 데이터 거버넌스 체계는 규제 준수를 넘어 데이터의 가치 창출과 위험 관리를 동시에 달성하기 위한 조직적 관리 체계임
- 데이터 관리의 기본 원칙, 책임 구조, 운영 절차를 명확히 정의하여 구성원이 데이터 처리 과정에서 참고할 수 있는 기준을 제공함
- 데이터 관리의 예측 가능성과 일관성을 확보하고 활용 과정의 혼선을 최소화함

○ 데이터 수집·이용·관리 기준의 표준화 필요성

- 다양한 부서와 연구 단위에서 각기 다른 목적과 방식으로 데이터를 수집·활용하고 있음
- 이러한 다양성은 유연성을 제공하지만, 관리 기준의 불일치로 법적·관리적 리스크를 증가시키는 요인이 됨
- 데이터 생애주기 전반에 적용 가능한 표준 관리 기준을 제시하여 부서별·사업별 처리 방식의 차이를 최소화함
- 수집 단계는 최소 수집·목적 명확화, 이용·제공 단계는 목적 외 이용 제한과 책임 명확화, 보관·파기 단계는 안전성과 적정성 확보를 목표로 함

○ 법적 리스크 최소화 및 기관 보호

- 데이터 관련 법령 위반은 과징금, 행정처분, 형사 책임 등 다양한 법적 위험으로 이어질 수 있음
- 2026년 개정법에 따라 반복·중대 위반 시 과징금이 전체 매출액의 10%까지 부과될 수 있고, 안전조치 위반 과태료도 900만~3,000만원으로 상향됨
- 개인정보 침해 사고는 장기적인 신뢰 하락과 평판 손실로 이어질 가능성이 큼
- 법령의 핵심 요구 사항을 내부 운영 기준으로 반영하여 법적 리스크를 사전에 관리하고, 예방 중심 관리 체계로 전환함
 - ※ 개정법은 개인정보 보호 투자·인력·조직 확충 실적이 있으면 과징금을 최대 40% 감경하므로 보호 활동의 기록 관리가 중요함

○ 연구·행정·산학협력 활동의 안정적 지원

- 본 가이드라인은 제한적 규범이 아니라 데이터의 안전한 활용을 통해 대학의 핵심 기능을 지원하는 것을 지향함
- 연구 분야는 연구 데이터의 체계적 관리와 공유 기준을 마련하여 연구 신뢰성과 투명성을 강화함
- 행정 분야는 데이터 기반 의사결정을 통해 업무 효율성을 높임
- 산학협력·외부 기관 데이터 연계 시 명확한 기준을 제시하여 법적·관리적 불확실성을 최소화하고 안정적인 협력 환경을 조성함

□ 적용 범위

○ 적용 대상

- 대학 내·외에서 발생하는 모든 데이터 처리 활동에 적용되며, 처리 주체와 관계없이 본 가이드라인의 원칙과 기준을 준수함
- 적용 조직: 본부, 단과대학, 부속기관, 연구소, 산학협력단, 병원 및 기타 대학 산하 조직
- 적용 인력: 교직원, 연구원, 강사, 직원, 조교 등 대학 구성원 전반
- 데이터 처리 업무를 직접 수행하지 않더라도 접근·활용 권한을 부여받은 구성원은 모두 적용 대상에 포함됨
- 각 조직은 수집·이용·관리·제공·파기 전 과정에서 책임 있는 관리 의무를 부담함

○ 외부 협력기관

- 업무 위탁 수탁자, 공동연구기관, 산학협력 기업 등 대학의 관리·감독 하에 데이터를 처리하는 외부 기관에도 적용함
- 위탁·협약 체결 시 본 가이드라인의 준수 의무를 계약서에 명시하고 이행 여부를 점검함

○ 적용 시점 및 공간적 범위

- 제정 또는 개정일 이후 발생하는 모든 데이터 처리 활동에 적용하며, 기존 보관 데이터도 취지에 맞게 단계적으로 정비함
- 데이터 처리 장소가 대학 내부인지 외부인지에 관계없이 적용함
- 대학 내부 시스템뿐 아니라 클라우드, 외부 데이터센터, 협력기관 시스템에서 처리되는 데이터도 포함함
- 국외 서버·시스템을 이용하더라도 처리 주체가 인제대학교이거나 대학의 관리·감독 하에 있으면 본 가이드라인을 준수함

○ 예외 및 특례

- 법령에 별도 규정이 있는 경우 해당 법령을 우선 적용하고, 법령에서 정하지 않은 사항은 본 가이드라인을 기준으로 판단함
- 국가 안보, 범죄 수사, 긴급 재난 대응 등 법령상 예외적으로 허용되는 처리는 법정 절차를 준수하되, 사후 관리와 기록 관리는 본 가이드라인에 따름
- 연구윤리·생명윤리 등 전문 규정이 적용되는 연구 데이터는 해당 규정과 본 가이드라인을 함께 적용하고, 상충 시 더 엄격한 기준을 우선 적용함

□ 가이드라인의 성격 및 다른 규정과의 관계

- 본 가이드라인은 인제대학교의 데이터 관리에 관한 기본 기준으로, 관련 규정·지침의 해석과 운영의 준거로 활용함

- 개인정보 보호법 등 상위 법령과 학내 규정(정보보안 규정, 연구윤리 규정, 기록물 관리 규정 등)에 어긋나지 않는 범위에서 적용함
- 세부 절차는 별도의 지침·매뉴얼·서식으로 정하며, 본 가이드라인과 상충하는 경우 본 가이드라인을 우선 적용함
- 본 가이드라인의 주요 근거 법령·지침은 다음과 같음

구분	근거	관련 사항
법률	개인정보 보호법 및 같은 법 시행령	처리 원칙, 안전조치, 유출 통지·신고, 보호책임자
고시	개인정보의 안전성 확보조치 기준	접근권한·인증·암호화·접속기록
지침	가명정보 처리 가이드라인, 보건의료데이터 활용 가이드라인	가명처리 절차, 연구데이터 심의
법률	인공지능기본법, 공공데이터법, 데이터기본법	AI 고지·표시, 공공데이터 개방, 데이터 활용
학내	정보보안 규정, 연구윤리 규정, 기관생명윤리위원회 운영 규정	보안 통제, 연구 심의

□ 용어 정의

용어	정의 및 관리 기준
개인정보	살아 있는 개인에 관한 정보로서 성명, 주민등록번호, 영상 등으로 개인을 알아볼 수 있는 정보(다른 정보와 쉽게 결합하여 알아볼 수 있는 정보 포함). 결합 가능성, 처리 맥락, 기술 발전에 따른 재식별 가능성을 고려하여 폭넓게 해석
민감정보	건강·의료 기록, 유전·생체인식정보, 범죄경력, 사상·신념 등 사생활을 현저히 침해할 우려가 있는 정보. 법령 근거 또는 별도 동의 없이 처리 불가, 강화된 접근 통제 적용
고유식별정보	주민등록번호, 여권번호, 운전면허번호, 외국인등록번호. 법령 근거 또는 별도 동의 필요, 암호화 저장 의무(주민등록번호는 법령 근거가 있는 경우에만 처리)
가명정보	일부 삭제·대체 등으로 추가 정보 없이는 특정 개인을 알아볼 수 없도록 처리한 정보. 통계 작성, 과학적 연구, 공익적 기록보존 목적으로 동의 없이 활용 가능하나 재식별 금지·추가정보 분리 보관 등 관리 필요
익명정보	시간·비용·기술 등을 합리적으로 고려할 때 다른 정보를 사용하여도 개인을 알아볼 수 없는 정보. 개인정보에 해당하지 않으나 결합 위험 등을 고려한 관리 필요
공공데이터	공공기관이 법령에 따라 생성·취득하여 관리하는 데이터로 국민에게 제공·활용될 수 있는 정보. 개방 시 투명성·책임성과 개인정보 보호의 균형 필요
연구데이터	연구 수행 과정에서 생성·수집·가공된 데이터로 연구 결과의 검증·재현에 필요한 자료. 국가R&D는 데이터관리계획(DMP) 대상(2027. 6. 국가연구데이터법 시행)
인공지능(AI) 학습데이터	AI 모델의 학습·검증·평가에 사용되는 데이터. 개인정보 포함 시 가명처리 원칙, 목적·보유기간 명확화
고영향 AI	보건의료·의료기기, 채용, 대출심사, 교육(학생평가) 등 생명·신체·기본권에 중대한 영향을 미칠 수 있는 AI(인공지능기본법)
데이터 거버넌스	데이터 전반에 대한 정책·기준·절차·역할·책임을 체계적으로 정의·관리하는 활동. 데이터거버넌스센터는 대학 내 데이터 관리의 컨트롤타워로서 보호와 활용의 균형을 유지

□ 데이터 거버넌스 개념

- 데이터 거버넌스의 정의
 - 조직 내에서 생성·수집·이용·관리되는 데이터 전반에 대해 정책, 기준, 절차, 역할, 책임을 체계적으로 정의하고 관리하는 활동
 - 기술적 관리나 보안 조치에 한정되지 않고, 데이터의 활용과 보호를 균형 있게 조정하기 위한 조직 차원의 관리 체계 전반을 포괄함
 - 데이터의 정확성·신뢰성·일관성을 확보하고 법적·윤리적·관리적 위험을 최소화하는 핵심 수단으로 작용함
 - 공공성과 책임성이 강조되는 대학에서는 선택 사항이 아닌 필수 관리 체계로 인식되고 있음
 - 본 가이드라인의 데이터 거버넌스는 대학 내 모든 데이터 처리 활동을 대상으로 생애주기 전반에 적용되는 관리 원칙과 운영 체계를 의미함
- 데이터 거버넌스의 필요성
 - 데이터 활용이 확대될수록 관리의 중요성도 비례하여 커지며, 체계적 관리 없이 활용을 확대하면 법적 리스크, 보안 사고, 신뢰도 저하 가능성이 커짐
 - 대학은 교육·연구·행정·산학협력 과정에서 개인정보, 민감정보, 연구 데이터, 공공데이터가 혼재되어 관리되고 있음
 - 개별 부서 단위 관리만으로는 데이터의 안전성과 일관성을 확보하기 어려움
 - 데이터 거버넌스는 관리 기준과 책임 주체를 분명히 하고, 데이터 관련 의사결정을 조직 차원에서 체계적으로 수행할 기반을 제공함
- 기대 효과
 - 관리의 일관성과 신뢰성 향상: 공통 기준과 절차로 데이터 품질이 개선되고 활용 결과의 신뢰도가 높아짐
 - 법적·제도적 리스크 감소: 개인정보 보호법 등 관련 법령을 체계적으로 반영하여 위반 가능성을 사전에 차단함
 - 활용 효율성 제고: 명확한 기준으로 연구·행정·산학협력 과정의 불확실성을 줄이고 업무 효율을 높임
 - 책임 있는 데이터 문화 정착: 구성원의 인식이 향상되고 책임 있는 데이터 활용 문화가 정착됨

□ 데이터거버넌스센터의 역할

- 정책 수립 기능
 - 대학 내 데이터 관리 관련 정책과 기준을 수립하는 핵심 조직으로서 수집·이용·제공·보관·파기 전 과정의 기본 원칙과 세부 기준을 마련함
 - 국내·외 데이터 보호 법령, 정부 가이드라인, 공공기관·대학 모범 사례를 종합 검토하여 인제대학교 실정에 맞는 기준을 도출함
 - 데이터 활용 환경 변화와 법·제도 개정 사항을 반영하여 정책을 지속적으로 개선함
- 관리·감독 기능
 - 수립된 정책과 기준이 현장에서 적절히 이행되는지 관리·감독함
 - 데이터 처리 활동 점검, 자체 이행점검, 내부 감사 지원을 수행하고 필요 시 개선 사항을 도출함
 - 처리 과정의 문제와 위험 요소를 사전에 식별하고 해결 방안을 제안함
 - 개인정보 침해 사고, 관리 부실 사례 발생 시 관련 부서와 협력하여 대응 방안과 재발 방지 대책을 수립함
- 지원 기능
 - 규제·통제 조직에 그치지 않고 데이터 활용을 지원하는 역할을 함께 수행함
 - 연구자, 행정 담당자, 산학협력 담당자가 참고할 가이드라인, 매뉴얼, 교육 자료를 제공함
 - 데이터 관련 문의 대응, 법령 해석 지원, 데이터 활용 컨설팅을 통해 안전하고 효율적인 활용을 지원함

□ 조직 및 역할 분담

구분	주요 역할
총장(대표자)	개인정보 보호의 최종 책임자로서 보호 전문 인력·예산 확보, 보호책임자 업무 지원(2026 개정법 반영)
총괄 책임자	데이터 관리 정책의 최종 책임, 주요 정책 결정·운영 방향 총괄, 자원 확보와 부서 간 협력 조정, 주요 의사결정 최종 승인
개인정보 보호책임자 (CPO)	개인정보 보호 업무 총괄, 전문 인력 관리·예산 확보, 보호 현황의 이사회·경영진 보고
데이터거버넌스센터 (실무 담당)	정책 이행 점검, 데이터 관리 현황 파악, 교육·홍보, 문서 관리, 현장 의견 수렴, 법·제도 변화 모니터링
부서별 분임책임자	소관 데이터 처리 현황 관리, 접근 권한 관리, 자체 점검 및 개선
협력 부서	정보보안·정보화·연구지원·산학협력·법무·감사 부서가 전문 영역에서 자문, 필요 시 공동 점검·개선

※ CPO 지정·변경·해제 시 이사회 의결 및 개인정보보호위원회 신고 의무 대상(재학생 2만명 이상 대학, 상급종합병원 등)은 학교법인·병원 단위로 해당 여부를 확인하여 이행

□ 역할별 책임 구분

○ 주요 업무별 책임 소재를 명확히 하여 업무 공백과 중복을 방지함

업무	총괄 책임자	센터	소관 부서	협력 부서
정책·기준 제정	승인	입안·조정	의견 제시	자문
데이터 등급 분류	-	검토·확정 지원	지정·관리	-
접근권한 부여·회수	-	기준 마련·점검	신청·관리	시스템 반영
자체 이행점검	결과 보고 접수	계획·총괄	자체 점검 수행	점검 지원
침해 사고 대응	최종 보고·대외 대응	총괄·조정	1차 대응·보고	기술 조치
교육	-	계획·운영	구성원 이수	지원
외부 제공·위탁 검토	고위험 승인	사전 검토	요청·계약	법무 검토

□ 연간 운영 체계

- 정기 운영: 연간 계획 수립(1분기), 자체 이행점검(반기 1회), 교육(연 1회 이상), 운영 실적 보고(연 1회)
- 수시 운영: 법·제도 개정 시 영향 분석, 신규 시스템·AI 서비스 도입 시 사전 검토, 사고 발생 시 대응
- 데이터 활용·제공 심의가 필요한 사안은 관련 부서가 참여하는 협의체를 구성하여 검토할 수 있음

□ 의사결정 체계

- 정책 변경 절차
 - 법·제도 변화, 기술 환경 변화, 운영 경험을 반영하여 데이터 관련 정책을 지속적으로 개선함
 - 변경 필요성이 발생하면 관련 부서 의견 수렴과 검토 절차를 거쳐 개정안을 마련함
 - 변경안은 영향 범위, 법적 검토, 운영 영향을 종합 검토한 후 승인 절차를 거쳐 확정함
- 내부 승인 흐름
 - 실무 검토 → 관련 부서 협의 → CPO·총괄 책임자 검토 → 최종 승인
 - 주요 보호 현황, 사고·민원, 개선이 필요한 위험 사항은 정기적으로 경영진(이사회)에 보고함
 - 의사결정 과정의 투명성과 책임성을 확보하여 구성원이 정책을 신뢰하고 준수할 수 있는 기반을 제공함

□ 국내 데이터 관련 법령 체계

○ 기본 방향

- 데이터거버넌스센터 운영은 단일 법령이 아닌 다수의 데이터·정보보호 관련 법령을 종합적으로 고려하여 이루어져야 함
- 국내 법령 체계는 개인정보 보호를 중심으로 공공데이터 활용, 데이터 산업 활성화, 인공지능, 분야별 데이터 보호 규정으로 구성되며 상호 보완적 관계를 가짐
- 대학은 공공기관이자 연구기관으로서 기업과 다른 법적 지위와 책임을 가지므로 개별 법령 취지를 정확히 이해하고 반영해야 함
 - ※ 개인정보 보호법 시행령상 「고등교육법」에 따른 학교는 공공기관 범위에 포함되므로 공공기관 의무를 함께 검토

○ 개인정보 보호법

- 국내 데이터 보호 법체계의 기본법으로서 개인정보의 수집·이용·제공·보관·파기 전 과정의 기본 원칙과 의무를 규정함
- 학생, 교직원, 연구 참여자, 의료 이용자 등의 개인정보는 모두 개인정보 보호법의 적용 대상임
- 처리의 적법성, 최소 수집, 목적 외 이용 제한, 안전성 확보 조치, 정보주체 권리 보장을 핵심 원칙으로 함
- 가명정보 제도로 통계 작성·과학적 연구·공익적 기록보존 목적의 활용이 확대되었으나 그에 따른 관리 책임도 강화됨
- 개인정보 처리방침을 수립·공개하고 내부관리계획을 마련하여 보호 체계를 운영해야 함
- 침해 사고 발생 시 법령에 따라 지체 없이 대응하고 통지·신고 의무를 이행해야 함

○ 2026년 개인정보 보호법 개정 주요 내용(2026. 9. 11. 시행)

구분	주요 내용	본교 시사점
대표자 책임	대표자·사업주를 개인정보 보호 최종 책임자로 명시, 인력·예산 확보 의무	총장 책임 명시, 보호 예산·인력 계획 수립
CPO 이사회 의결·신고	지정·변경·해제 시 이사회 의결 후 6개월 이내 신고, 기존 CPO는 2027. 3. 11.까지 신고(2027. 12. 31.까지 계도기간)	학교법인·백병원 단위 대상 여부 확인
유출 가능성 통지	유출 확정 전이라도 가능성 인지 시 72시간 이내 통지, 위조·변조·훼손 포함, 통지 항목에 손해 배상·분쟁조정 청구 방법 추가	사고대응 절차 개정
과징금 강화	상한 전제 매출액 3% → 10%(3년 내 반복, 1천만명 이상 피해, 시정명령 불이행), 보호 투자 시 최대 40% 감경	보호 투자·조직 실적 기록 관리
과태료 상향	안전조치 위반 과태료 900만~3,000만원(위반 횟수별 상향)	안전조치 이행 점검 강화
인증 의무화	일정 규모 이상 처리자 ISMS-P 인증 의무(2027. 7. 1. 시행, 대상 고시 예정)	고시 확정 시 대상 여부 검토

○ 개인정보의 안전성 확보조치 기준(고시) 개정

- 2025. 10. 31. 개정 시행으로 일률적 인터넷망 차단 조치를 위험 기반 방식으로 개선함
- 접근권한 차등 부여, 안전한 인증, 접속기록 관리 대상을 개인정보취급자에서 정보주체를 제외한 전체 이용자로 확대(2026. 10. 30. 시행)
- 접속기록 월 1회 점검 의무를 폐지하고 점검 주기·방법·후속조치를 내부관리계획에 정하도록 변경함
- 내부관리계획에 출력·복사 시 안전조치와 개인정보 파기 절차를 포함하도록 함

○ 공공데이터의 제공 및 이용 활성화에 관한 법률

- 공공기관이 보유·관리하는 데이터를 국민에게 개방하여 공공 서비스 혁신과 데이터 활용을 촉진하는 것을 목적으로 함
- 인제대학교는 공공기관 성격을 가지는 기관으로서 일정 범위의 데이터를 공공데이터로 제공할 책임을 가짐
- 개방 과정에서는 개인정보 보호를 최우선으로 고려하고, 식별 가능성이 있는 정보는 비식별 처리하거나 제공 대상에서 제외함
- 개방 전 데이터 품질 점검, 법적 검토, 사전 심의 절차를 거치며, 센터는 개방 정책과 보호 정책 간 균형을 유지함

○ 인공지능 및 데이터 기반 행정 활성화에 관한 법률(2026. 8. 28. 시행)

- 기존 「데이터기반행정 활성화에 관한 법률」을 전면 개편하여 인공지능·학습용데이터 정의를 신설함
- 공공 AI·데이터 공통 기반 구축, 학습데이터 품질관리, 공무원 AI 교육 등 공공부문 AI 도입의 법적 기반을 마련함
 - ※ 사립대학의 적용 대상 여부는 추가 확인이 필요하며, 공공기관과 데이터 연계 시 품질 기준을 참고

○ 데이터 산업진흥 및 이용촉진에 관한 기본법

- 데이터의 생산·유통·활용을 촉진하여 데이터 기반 산업 생태계를 조성하는 것을 목적으로 함
- 데이터 결합, 데이터 거래, 데이터안심구역 등 활용 기반 조성을 지원함

- 연구·산학협력 활동을 통해 데이터 산업과 밀접하게 연계되므로 법 취지를 고려한 활용 전략이 필요함
- 연구·산학협력 데이터 활용 시 데이터 보호와 산업적 활용 간 균형이 중요하며, 센터는 관련 관리 기준을 마련함
 - ※ 국가데이터기본법 제정이 추진 중(2026. 9. 공청회)으로 입법 동향을 모니터링

○ 인공지능 발전과 신뢰 기반 조성 등에 관한 기본법(인공지능기본법, 2026. 1. 22. 시행)

- AI를 개발하는 개발사업자뿐 아니라 외부 AI를 활용해 서비스를 제공하는 이용사업자도 의무 주체가 될 수 있음
- 투명성 확보: 생성형·고영향 AI 사용 사실 사전 고지, AI 생성 결과물 표시(딥페이크는 명확히 표시)
- 고영향 AI: 위험관리·설명 방안·이용자 보호 방안 수립, 관련 문서 보관
- 과태료 최대 3천만원이나 최소 1년 이상 계도기간 운영
 - ※ 대학 관련 고영향 AI 영역: 보건의료·의료기기(백병원 의료 AI), 채용 등

○ 보건의료·연구 분야 법령

- 생명윤리법: 인간대상연구·인체유래물연구는 기관생명윤리위원회(IRB) 심의 필수
- 의료법: 전자의무기록 관리 의무, 2026. 12. 10.부터 열람 시에도 기록 보관
- 보건의료데이터 활용 가이드라인(2025. 12. 31. 개정): 공용 데이터심의위원회(DRB) 도입, IRB·DRB 표준 심의 절차, 사망자 데이터 활용 기준
- 국가연구데이터 관리 및 활용 촉진에 관한 법률(2026. 6. 9. 공포, 2027. 6. 10. 시행): 국가R&D 데이터관리계획(DMP) 제출, 연구데이터 등록·공개 원칙

○ 신용정보법 등 개별 법령

- 신용정보법은 금융·신용 정보를 엄격히 보호하며, 위치정보법은 위치정보 수집·이용을 규율함
- 금융 관련 연구, 의료 연구, 산학협력 프로젝트 수행 시 해당 분야 개별 법령을 함께 고려함
- 센터는 개별 법령 간 적용 관계를 정리하여 현장 혼선을 방지함

□ 국제 데이터 보호 규범

○ GDPR 개요

- EU가 제정한 개인정보 보호 규범으로 가장 엄격한 국제 기준 중 하나이며, 투명성·책임성·정보주체 권리 강화를 핵심 원칙으로 함
- EU 거주자의 개인정보를 처리하는 모든 기관에 적용되며 역외 기관에도 적용될 수 있음
- EU 거주자 대상 연구, 국제 공동연구 과정에서 EU 거주자 개인정보를 처리하는 경우 GDPR 적용 가능성을 검토함
 - ※ EU Digital Omnibus에 따른 GDPR 개정안(2025. 11. 제안)은 2026. 9. 현재 미채택으로 현행 GDPR 기준을 적용

○ 국외 이전 규정

- EU 외 국가로 이전하려면 적정성 결정, 표준계약조항(SCC), 구속력 있는 기업 규칙(BCR) 등 적절한 보호조치가 필요함
- 한국은 2021. 12. EU 적정성 결정을 받았으며 2026. 7. 23. 1차 검토에서 적정성이 유지됨(제3국 재이전 관련 보완 권고)
- 개인정보보호위원회가 2025. 9. EU를 보호수준 동등 국가로 인정하여 EU로의 이전 여건이 개선됨
- 클라우드, 해외 연구기관, 국제 공동연구로 국외 이전 시 국내법과 GDPR 국외 이전 규정을 함께 고려하며, 센터가 사전 검토를 지원함

○ 역외 적용

- EU 역외 기관이라도 EU 거주자에게 상품·서비스를 제공하거나 행동을 모니터링하면 GDPR이 적용될 수 있음
- 국제 학술 연구, 해외 온라인 서비스, 글로벌 플랫폼 활용 과정에서 역외 적용 문제가 발생할 수 있어 사전 검토가 필요함

○ 기타 주요 국제 규범

규범	주요 내용	본교 유의사항
EU AI Act	교육 등 고위험 AI 적용 2027. 12. 2.로 연기(AI Omnibus, 2026. 7. 발효), 투명성 의무는 2026. 8. 2.부터 적용	EU 대상 교육·평가 AI 활용 시 검토
EU Data Act	2025. 9. 12. 적용, 연결 제품 데이터 접근·공유 권리	산학협력 IoT 데이터 계약 시 참고
EHDS 규정	유럽보건의료데이터공간, 2027. 3. 26.부터 단계 적용	EU 보건의료 데이터 공동연구 시 허가 절차 확인
GDPR 절차규정	2027. 4. 2. 이후 접수 국경 간 민원부터 적용	EU 정보주체 민원 대응 절차 참고
미국 대량 민감 데이터 규칙	우려국 대상 유전체·건강 등 대량 민감데이터 이전 제한(2025. 4. 8. 시행)	미국 데이터 활용 공동연구 시 재이전 제한 확인
NIH 데이터 보안 요건	통제접근 데이터 이용 시 NIST SP 800-171 수준 보안 요구	NIH 데이터 이용 연구 보안환경 점검

□ 대학·공공기관 적용 시 유의사항

○ 기업과의 차이

- 대학은 영리 기업과 달리 공공성, 투명성, 책임성을 중시하는 조직으로 데이터 활용 목적과 범위가 다르게 설정됨
- 기업은 수익 창출 중심으로, 대학은 연구·교육·공공 서비스 제공 중심으로 데이터를 활용하므로 보호 기준을 보다 엄격하게 적용함

○ 연구기관으로서의 특성

- 연구 데이터의 자유로운 활용과 학문 발전을 보장하는 동시에 연구 참여자의 권리 보호와 데이터 윤리를 준수해야 함
- 연구 데이터는 학문적 가치가 크지만 개인정보·민감정보를 포함하는 경우가 많아 관리가 어려움
- 연구 자율성과 법적 책임을 동시에 고려한 균형 있는 접근이 필요하며, 센터는 연구윤리·생명윤리·개인정보 보호 기준을 종합 반영하여 지원함

□ 데이터 수집 단계

○ 수집 목적의 명확화

- 수집 단계는 생애주기 전반의 적법성과 신뢰성을 결정하는 핵심 단계로, 수집 목적의 명확한 설정이 가장 중요함
- 모든 수집 활동은 사전에 구체적인 목적을 설정하고, 법령·정책·사업계획·연구계획 등 객관적으로 확인 가능한 근거를 기반으로 함
- 목적은 포괄적·추상적으로 설정하지 않고 실제 활용 방식을 기준으로 구체화함
 - ※ 예: '연구 활용'이 아닌 '○○ 연구과제 수행을 위한 통계 분석'과 같이 활용 범위를 명시
- 센터는 목적의 적정성을 사전 검토하고, 불명확하거나 과도한 경우 개선을 권고할 수 있음
- 목적이 변경되면 재검토 절차를 거치고, 필요 시 동의 또는 법적 근거를 다시 확보함

○ 최소 수집 원칙

- 목적 달성에 필요한 최소한의 범위에서만 수집하며, 이는 과잉 수집으로 인한 침해를 예방하기 위한 법령상 핵심 원칙임
- 필수 정보와 선택 정보를 명확히 구분하고, 선택 정보 미제공이 서비스 이용이나 연구 참여에 불이익이 되지 않도록 함
- 개인정보·민감정보 중 목적 달성에 필수적이지 않은 정보는 원칙적으로 수집하지 않음
- 센터는 최소 수집 준수 여부를 점검하고, 반복적 과잉 수집 시 개선 조치를 요구할 수 있음

○ 동의 관리

- 동의는 자유롭고 명확하며 구체적으로 이루어져야 하며, 수집 목적·항목·보유기간·이용·제공 여부를 명확히 고지함
- 민감정보, 고유식별정보, 국외 이전, 제3자 제공은 다른 사항과 구분하여 별도 동의를 받음
- 동의가 형식적 절차에 그치지 않도록 정보주체가 충분히 이해한 상태에서 이루어지게 함
- 연구 참여자, 의료 이용자 등 상대적으로 취약한 정보주체는 동의 절차의 공정성과 투명성을 더욱 강화함
- 센터는 동의서 양식 표준화, 전자적 동의 관리 시스템 도입 등으로 동의 관리를 체계화함

□ 데이터 저장·보관 단계

○ 보관 기간 설정

- 목적 달성 후에는 지체 없이 파기하는 것을 원칙으로 하며, 법령·내부 규정에서 정한 경우에만 해당 기간 동안 보관함
- 보관 기간은 데이터 유형, 목적, 법적 요구사항을 종합 고려하여 설정하며 '무기한 보관'과 같은 불명확한 기준은 허용하지 않음
- 연구 데이터도 연구 종료 후 보관이 필요할 수 있으나 명확한 보관 기간을 설정함
- 센터는 데이터 유형별 표준 보관 기간을 제시하고 각 부서의 보관 정책 수립을 지원함

○ 접근 통제

- 접근 권한은 최소 권한 원칙에 따라 업무 수행에 필요한 범위로 차등 부여하며, 범위를 초과하는 접근은 제한함
- 권한은 정기적으로 검토·조정하고 인사이동, 퇴직, 역할 변경 시 지체 없이 변경·말소함
- 개인정보·민감정보는 이중 인증, 접근 기록 관리 등 강화된 통제를 적용함
- 2026. 10. 30.부터 접근권한 관리·인증·접속기록 대상이 정보주체를 제외한 전체 이용자로 확대됨

○ 보안 관리

- 기술적·관리적·물리적 보호조치를 포함하며, 저장 데이터는 암호화·백업·위변조 방지 조치로 보호함
- 클라우드·외부 데이터센터 활용 시 관련 법령과 내부 보안 기준 충족 여부를 사전에 검토함
- 보안 사고 가능성을 최소화하기 위해 정기 점검과 모의 훈련을 실시함

□ 데이터 이용·제공 단계

○ 목적 외 이용 제한

- 수집 데이터는 사전에 고지한 목적 범위 내에서만 이용하며, 목적 외 이용은 원칙적으로 금지함
- 목적 외 이용이 필요한 경우 법령 근거 또는 정보주체의 추가 동의를 받음
- 연구·행정·산학협력 목적 간 데이터 전용은 엄격히 관리하며 단순 편의를 이유로 한 목적 외 이용은 허용하지 않음

○ 제3자 제공 기준

- 외부 제공 시 법적 근거, 제공 목적, 제공 범위, 보호조치를 사전에 명확히 검토함
- 개인정보 제3자 제공은 권리 침해 가능성이 크므로 엄격한 기준을 적용하고, 제공 내역을 기록·관리함
- 필요 시 정보주체에게 제공 사실을 통지하며, 센터는 고위험 제공 사례에 대해 사전 심의를 수행할 수 있음
- 업무 위탁은 제3자 제공과 구분하여 위탁 계약서 작성, 수탁자 공개, 수탁자 교육·점검을 이행함

○ 내부 공유 기준

- 부서 간 공유도 명확한 기준에 따라 이루어지며, 목적 외 이용에 해당하면 제한되고 필요 시 내부 승인 절차를 거침
- 데이터 최소화, 접근 통제, 기록 관리를 통해 내부 오·남용을 방지함

□ 데이터 파기 단계

○ 파기 기준

- 보관 기간 종료 또는 처리 목적 달성 시 지체 없이(원칙적으로 5일 이내) 파기함
- 파기 기준은 데이터 유형별로 명확히 설정하며 임의 판단으로 파기를 지연하지 않음
- 법령에 따라 보존해야 하는 경우 다른 데이터와 분리하여 저장·관리함

○ 파기 방법

- 전자파일은 복구가 불가능한 방식으로 영구 삭제하고, 출력물 등 물리적 매체는 파쇄 또는 소각함
- 파기 방법은 데이터의 민감도에 따라 차등 적용할 수 있음

○ 기록 관리

- 파기 일자, 대상, 방법, 확인자를 기록하여 사후 감사와 분쟁 발생 시 근거 자료로 활용함
- 센터는 파기 기록 관리 기준을 마련하고 정기 점검으로 파기 절차의 적정성을 확인함

□ 개인정보 처리 원칙

○ 기본 방향

- 개인정보 보호를 데이터 거버넌스 운영의 최우선 가치로 인식하고 처리 전 과정에서 법령상 기본 원칙을 준수함
- 처리 원칙은 선언적 기준이 아니라 수집·이용·관리·파기 전반에 적용되는 실질적 운영 기준으로 기능해야 함

○ 최소 수집 원칙

- 처리 목적 달성에 필요한 최소 범위에서 수집하며, 이는 침해 위험을 사전에 차단하는 기본 보호 장치임
- 필수·선택 항목을 명확히 구분하고 선택 항목 미제공에 따른 불이익이 없도록 함
- 연구·행정·산학협력 과정에서 관행적으로 수집하던 불필요 항목은 정기적으로 재검토하여 축소·삭제함
- 센터는 최소 수집 준수 여부를 자체 이행점검 항목으로 관리하고 반복적 과잉 수집 시 개선을 요구함

○ 목적 제한 원칙

- 수집 시 고지한 목적 범위 내에서만 처리하며, 목적 외 이용·제공은 원칙적으로 금지함
- 목적 제한은 개인정보 자기결정권 보호의 핵심 원칙으로 데이터 활용 확대 과정에서도 반드시 준수함
- 목적이 변경·추가되면 정보주체에게 고지하고 필요 시 추가 동의를 받음
- 처리 목적은 개인정보 처리방침, 동의서, 내부 문서로 관리하고 센터는 목적 변경에 따른 위험을 사전 검토함

○ 안전성 확보 원칙

- 분실·도난·유출·위조·변조·훼손되지 않도록 기술적·관리적·물리적 보호조치를 종합 적용함
- 기술적 조치: 접근 통제, 암호화, 접속기록 관리, 보안 프로그램 설치
- 관리적 조치: 내부관리계획 수립, 교육, 점검 절차 운영
- 물리적 조치: 전산실·문서보관 장소 출입 통제
- 센터는 개인정보의 안전성 확보조치 기준(고시)과 안내서를 기준으로 보호 수준을 지속 점검·개선함

□ 적법 처리 근거

○ 개인정보는 법령이 허용하는 적법한 근거에 따라 처리하며, 목적별로 적절한 근거를 구분하여 적용함

근거	대표 사례	유의사항
정보주체의 동의	행사 참가, 선택 항목 수집, 연구 참여	충분한 정보 제공, 철회 보장, 민감·고유식별·국외이전은 별도 동의
법령상 의무	학사 관리, 인사·회계 처리, 법정 보고	법령이 요구하는 최소 범위, 보관기간 초과 금지
계약 체결·이행	입학·등록·장학 등 학생과의 계약 이행	계약 이행에 필요한 범위 내에서 처리
공익·가명처리 특례	통계 작성, 과학적 연구, 공익적 기록보존	가명처리 우선 적용, 가명정보 처리 가이드라인 절차 준수

○ 정보주체의 동의

- 동의는 개인정보 처리의 가장 일반적인 근거로 자발적·구체적·명확하게 이루어져야 함
- 수집 목적, 항목, 보관 기간, 이용·제공 여부, 권리 행사 방법을 명확히 고지함
- 동의는 언제든지 철회할 수 있어야 하며 철회에 따른 불이익이 없도록 관리함

○ 법적 의무에 따른 처리

- 법령상 처리가 요구되는 경우 동의 없이 처리할 수 있으나, 처리 범위는 법령이 요구하는 최소 수준으로 제한함
- 센터는 법적 의무에 따른 처리 항목을 정리하여 내부 기준으로 관리함

○ 공익 목적에 따른 처리

- 통계 작성, 과학적 연구, 공익적 기록보존 목적은 법령 요건을 충족하는 범위에서 동의 없이 처리 가능하며 가명처리를 우선 적용함
- 연구 활동의 공익성을 이유로 개인정보 보호 원칙이 완화되어서는 안 되며, 센터가 적법성과 보호 수준을 사전 검토함

□ 정보주체 권리 보장

○ 열람·정정·삭제 권리

- 정보주체는 자신의 개인정보 열람, 부정확하거나 불안정한 정보의 정정, 법령 허용 범위 내 삭제를 요구할 수 있음
- 요구는 원칙적으로 10일 이내 처리하고 결과를 통지하며, 권리 행사로 인한 불이익을 주지 않음

○ 처리정지 요구권

- 정당한 사유가 있는 경우 처리정지를 요구할 수 있으며, 관련 부서는 법령에 따라 처리 가능 여부를 검토하여 결과를 통지함
- 센터는 처리정지 요청이 반복되는 업무 영역을 분석하여 제도 개선에 반영함

○ 자동화된 결정에 대한 권리

- AI 등 완전히 자동화된 시스템으로 권리·의무에 중대한 영향을 미치는 결정을 하는 경우 거부·설명 요구권을 보장함
- AI 기반 평가·선발·추천 시스템 도입 시 자동화된 결정 해당 여부와 기준 공개 방안을 사전 검토함

○ 개인정보 전송요구권

- 정보주체가 본인 정보를 본인 또는 제3자에게 전송하도록 요구할 수 있는 권리(보건의료·통신 분야 2025. 3. 시행)
- 교육 분야(학적·수강·성적·졸업 정보)로 확대가 추진 중이므로 적용 대상·시기를 모니터링하여 대응함

○ 권리 행사 절차

- 서면, 전자적 방법 등 다양한 방식으로 권리를 행사할 수 있도록 보장함
- 권리 행사 절차는 개인정보 처리방침으로 안내하며 처리 기한과 담당 부서를 명시함
- 센터는 권리 행사 처리 현황을 관리하고 분쟁 발생 시 조정 역할을 수행함

□ 개인정보 국외 이전

○ 국외 이전 요건(개인정보 보호법 제28조의8)

요건	내용
별도 동의	이전 항목·국가·시기·방법, 이전받는 자, 목적·보유기간, 거부 방법 등을 고지하고 별도 동의
법률·조약	법률, 대한민국을 당사자로 하는 조약 등에 국외 이전 규정이 있는 경우
처리위탁·보관	계약 체결·이행을 위한 위탁·보관으로 처리방침에 공개하거나 정보주체에게 알린 경우
인증	이전받는 자가 개인정보보호위원회가 고시하는 인증을 받은 경우
동등성 인정	이전 국가의 보호 수준이 국내와 실질적으로 동등하다고 개인정보보호위원회가 인정한 경우(EU 인정, 2025. 9.)

○ 보호조치

- 이전받는 자의 보호 수준을 검토하고 계약서에 보호조치 의무, 접근 통제, 암호화, 재이전 제한을 명시함
- GDPR 적용 대상인 경우 표준계약조항(SCC) 등 국제 기준을 함께 고려함
- 미국 데이터를 활용하는 국제 공동연구는 미국 법무부 대량 민감데이터 규칙에 따른 재이전 제한 여부를 확인함

○ 관리 절차

- 국외 이전 현황을 체계적으로 관리하고 이전 내역을 기록·보관함
- 센터는 국외 이전 사전 검토, 사후 점검, 정기 현황 관리를 수행함

※ 요건을 위반하거나 보호조치 미흡으로 피해가 우려되면 개인정보보호위원회가 국외 이전 중지를 명할 수 있음

□ 관리적 보호조치

○ 기본 방향

- 관리적 보호조치를 데이터 거버넌스 체계의 핵심 요소로 설정하며, 기술적·물리적 조치의 기반으로 조직 차원의 책임성과 지속적 관리 체계를 확보함

○ 내부관리계획 수립 및 운영

- 개인정보 보호법과 안전성 확보조치 기준에 따라 개인정보 및 중요 데이터 보호를 위한 내부관리계획을 수립·운영함
- 내부관리계획은 데이터 처리 전반의 관리 기준을 문서화한 것으로 조직 내 보호 활동의 기준점 역할을 함
- 포함 사항: 보호책임자·취급자 지정과 역할, 처리 절차·보호 기준, 접근 권한 부여·변경·말소 기준, 침해 사고 대응 절차, 위탁·외부 제공 관리 기준, 점검·개선 절차
- 2025. 10. 개정 고시에 따라 출력·복사 시 안전조치, 파기 절차, 접속기록 점검 주기·방법을 추가로 포함함
- 형식적 문서에 그치지 않도록 실제 운영에 활용하고, 법령 개정·조직 환경 변화 시 정기적으로 검토·개정함
- 센터는 내부관리계획의 수립·개정 및 이행 여부를 총괄 관리함

○ 교육 및 점검

- 데이터 처리에 관여하는 모든 구성원을 대상으로 정기적인 개인정보 보호·데이터 보안 교육을 실시함
- 교육은 법령 이해, 실제 사고 사례, 내부 규정, 주의사항을 포함한 실무 중심으로 운영하고, 신규 임용자·역할 변경자에게 맞춤형 교육을 제공함
- 생성형 AI 활용 시 개인정보·기밀정보 입력 금지 등 AI 활용 보안 수칙을 교육 내용에 포함함
- 자체 이행점검, 내부 점검, 감사 대응을 통해 이행 여부를 주기적으로 점검하고, 미흡 사항은 개선계획 수립 후 재발을 방지함
- 센터는 교육 이수 현황과 점검 결과를 체계적으로 관리하여 지속적 개선 활동으로 연계함

○ 교육 체계

대상	주기	주요 내용
전 구성원	연 1회 이상	개인정보 보호 법령, 내부 기준, 사고 사례, AI 활용 수칙
개인정보취급자	연 1회 이상(별도)	취급 데이터 등급, 접근권한 관리, 반출 절차, 유출 시 대응
연구자	연구 착수 시	연구데이터 관리, IRB·DRB 심의, 가명처리, 데이터관리계획(DMP)
신규 임용자·역할 변경자	임용·변경 후 1개월 이내	기본 보호 수칙, 담당 업무별 준수 사항
시스템 운영자	연 1회 이상	접근 통제·계정 관리, 로그 점검, 설비 비상 대응

- 교육 이수 현황을 관리하고 미이수자에게 보완 교육을 실시함

□ 기술적 보호조치

○ 기본 방향

- 데이터의 무단 접근·유출·훼손을 방지하는 핵심 수단으로 정보시스템 전반에 적용하며, 중요도·민감도에 따라 차등 적용함

항목	세부 기준
접근 통제	업무상 필요한 최소 범위로 사용자·역할별 권한 부여, 권한 부여·변경·말소 기록 보관, 장기 미사용 계정 관리, 권한 정기 점검
인증	안전한 비밀번호 작성 규칙, 외부 접속 시 OTP·인증서 등 안전한 인증수단 적용(대상: 정보주체 외 전체 이용자, 2026. 10. 30.)
암호화	고유식별정보·비밀번호(일방향)·생체인식정보 암호화 저장, 정보통신망 전송 시 암호화, 암호키 별도 관리
접속기록	접속 일시·사용자·접근 대상·수행 업무 기록, 1년 이상 보관(5만명 이상·민감·고유식별정보 처리 시스템은 2년 이상), 위변조 방지
악성코드 방지	보안 프로그램 설치·자동 업데이트, 보안 패치 적용
망 관리	일률적 인터넷망 차단 대신 위험 분석에 따른 보호 조치 적용(2025. 10. 개정 고시)

○ 접근 통제

- 개인정보·민감정보가 포함된 시스템은 사용자 인증·권한 관리, 이중 인증, 권한 정기 점검, 장기 미사용 계정 관리 등 강화된 통제를 적용함
- 접근 통제 기준은 내부관리계획과 연계하여 운영하고 센터는 정책의 적정성을 주기적으로 점검함

○ 암호화

- 주민등록번호, 계좌번호, 의료 정보 등 고위험 정보는 안전한 암호화 알고리즘으로 저장하고 전송 시 암호화 통신을 적용함
- 암호화 키는 별도 관리 체계로 보관하고 접근 권한을 엄격히 제한하며, 센터는 이행 여부를 점검함

○ 로그(접속기록) 관리

- 정보시스템 접근과 데이터 처리 이력을 로그로 기록·관리하여 사후 사고 분석, 내부 통제, 감사 대응에 활용함
- 접속기록 점검 주기·방법은 내부관리계획에 정하고 점검 결과 이상 징후 발견 시 후속 조치를 취함
- 백병원 전자의무기록은 2026. 12. 10.부터 열람 시에도 기록을 보관함(의료법 개정)

□ 물리적 보호조치

○ 시설 보호

- 전산실, 서버실, 문서 보관실 등 주요 시설은 외부인의 무단 출입을 방지할 수 있도록 보호함
- 잠금 장치, 감시 장비, 화재·재난 대응 설비를 설치하여 안전한 운영 환경을 유지함
- 집적정보통신시설 또는 외부 데이터센터 활용 시 관련 법령과 보안 기준 충족 여부를 사전 검토함

○ 출입 통제

- 중요 시설 출입은 인가된 인원으로 제한하고 출입 기록을 관리하며, 출입 권한은 업무 필요성에 따라 부여·정기 회수함
- 외부 인원 출입은 사전 승인을 거쳐 출입 목적과 시간을 기록함
- 개인정보가 포함된 서류·보조저장매체는 잠금장치가 있는 안전한 장소에 보관함
- 센터는 물리적 보호조치 운영 현황을 점검하여 취약 요소를 개선함

○ 보호구역 지정 및 차등 통제

구역	대상	통제 기준
일반구역	사무실, 회의실 등	출입증 확인, 개인정보 서류 잠금 보관
제한구역	부서 서버 보관실, 문서 보관실	인가자 출입, 출입 기록 관리, 외부인 동행
통제구역	전산실, 폐쇄망 분석실, 백업 보관 장소	2단계 인증(카드+생체 등), CCTV 상시 녹화, 출입 기록 정기 점검, 저장매체·촬영기기 반입·반출 통제

- 통제구역의 보조저장매체·노트북 반입·반출은 사전 승인 및 기록 대장으로 관리함
- CCTV 영상은 개인정보 보호법상 영상정보처리기기 운영 기준(안내판 설치, 보관기간 설정)을 준수함

□ 연구 데이터

○ 연구 목적 활용 원칙

- 연구 데이터는 학문적 연구·연구개발 과정에서 생성·수집·가공되는 데이터로서 학문 발전과 공익 증진을 목적으로 활용됨
- 연구 데이터의 자유로운 활용을 보장하는 동시에 연구 참여자의 권리 보호와 데이터 보호 책임을 함께 고려함
- 연구계획서에 명시된 목적 범위 내에서만 활용하며, 연구 목적과 무관한 이용이나 타 연구로의 전용은 제한함
- 개인정보·민감정보가 포함된 연구 데이터는 연구 종료 후에도 목적 외 이용이 발생하지 않도록 관리함
- 센터는 연구 지원 부서·연구자와 협력하여 법적·윤리적 위험이 발생하지 않도록 관리 기준을 제공함

○ IRB 연계 관리

- 사람을 대상으로 하거나 개인정보·민감정보를 포함하는 연구는 기관생명윤리위원회(IRB) 심의를 받아야 함
- 연구자는 심의 시 수집 항목, 활용 목적, 보관 기간, 보호 조치를 명확히 제시하고 승인 범위를 초과하여 처리하지 않음
- IRB 승인 내용과 실제 처리 방식의 일치 여부를 관리하며, 센터는 연구 종료 후 보관·파기 단계까지 관리를 지원함

○ 의료데이터 심의(IRB·DRB 연계)

- 병원 의료데이터 활용 시 보건의료데이터 활용 가이드라인(2025. 12. 개정)에 따라 데이터심의위원회(DRB) 심의를 거침
- DRB 심의를 IRB 심의보다 먼저 진행하는 표준 절차를 권고하며, 자체 DRB 운영이 어려우면 공용 DRB를 활용함
- 사망자 데이터는 가이드라인의 비식별 기준에 따라 활용함

○ 가명정보 처리

- 연구 목적 활용 시 개인정보 보호 강화를 위해 가명처리를 우선 고려함
- 가명정보 처리 가이드라인(2026. 3. 전면개정)의 위험도 기반 절차를 적용함

위험도	해당 유형	처리 절차
저위험	본교 내부 이용(동일 기관 내 활용)	부서 검토 중심 간소화 절차, 최소 서식 작성
중위험	처리환경 통제가 가능한 제3자 제공	적정성 검토, 제공 계약·안전조치 확인
고위험	처리환경 통제가 어려운 제3자 제공	위원회 심의 등 강화된 적정성 검토, 추가 안전조치

- 재식별 가능성을 최소화하는 기술적·관리적 조치를 적용하고 가명정보와 추가정보를 분리 보관함
- 외부 기관과의 가명정보 결합은 결합전문기관을 통해 수행하며 사전 검토 절차를 거침
- AI 개발 목적은 확장 가능한 목적을 사전 설정할 수 있고, 영상·이미지 등 비정형데이터는 표본 검증을 활용할 수 있음
- 가명정보 처리 기록을 작성·보관하며, 센터는 처리 기준과 자문을 제공함

○ 연구데이터 관리계획(DMP)

- 국가연구데이터법(2027. 6. 10. 시행)에 따라 국가R&D 과제는 데이터관리계획 제출과 연구데이터 등록·연계가 요구됨
- 연구데이터는 공개를 원칙으로 하되 개인정보·영업비밀 등은 기한을 정해 비공개 가능하므로 공개 범위를 사전 설계함
- 센터는 연구지원 부서와 협력하여 DMP 작성 지원, 보관·공개 절차를 마련함

□ 행정·학사 데이터

○ 학생·교직원 정보 관리

- 행정·학사 데이터는 학생, 교직원, 강사 등 구성원의 개인정보를 포함하는 대학 운영의 기본 데이터임
- 학사·인사·재정 관리 등 명확한 목적에 따라 법령 근거 또는 업무상 필요한 범위에서만 수집·이용하며 목적 외 이용은 제한함
- 학사 시스템, 인사 시스템 등 주요 정보시스템에는 강화된 접근 통제와 보안 조치를 적용함
- 센터는 처리 기준을 정리하여 부서 간 관리 방식 차이로 인한 혼선을 최소화함

○ 내부 공유 기준

- 업무 수행에 필요한 경우에 한해 명확한 기준과 절차에 따라 공유하며, 내부 공유에도 개인정보 보호 원칙을 동일하게 적용함
- 공유 목적·범위·기간을 명확히 하고 불필요한 항목은 제거하여 제공하며, 공유 내역을 기록·관리함

- 센터는 반복적으로 발생하는 공유 사례에 대해 표준 절차를 제시함

○ 개인정보 처리방침 관리

- 개인정보 처리방침은 실제 처리 현황과 일치하도록 정기적으로 갱신함
- 개인정보보호위원회 처리방침 평가(2026년 대학 분야 포함)에 대비하여 사전 점검함

□ 산학협력 및 외부 연계 데이터

○ 기업 협력 시 데이터 관리 기준

- 산학협력·외부 연계 과정에서는 대학과 기업·기관 간 데이터 공유와 공동 활용이 빈번하게 발생함
- 데이터 소유권, 이용 범위, 보호 책임이 불명확하면 분쟁 위험이 발생하므로 사전에 관리 기준과 제공·공유 범위를 명확히 함
- 개인정보가 포함된 경우 가명처리 또는 비식별 처리를 우선 적용함
- 센터는 산학협력 데이터 관리 기준의 법령·내부 정책 부합 여부를 검토하고 필요 시 개선을 권고함

○ 계약 및 책임 관리

- 계약서에 이용 목적, 제3자 제공 여부, 보관 기간, 파기 의무, 침해 사고 시 책임, 재제공 금지를 포함함
- 외부 기관에 처리 업무를 위탁하는 경우 수탁자 관리·감독 의무를 명확히 하고 정기 점검으로 이행 여부를 확인함
- 센터는 표준 계약 조항 마련과 계약 검토 지원으로 데이터 분쟁 위험을 최소화함

□ 공공데이터 개방

○ 개방 대상 데이터 선정

- 공공데이터 개방은 공공기관의 투명성과 데이터 활용 촉진을 위한 정책 수단으로, 공공데이터법에 따라 개방 대상을 검토·선정함
- 개인 식별 가능성이 없거나 비식별 조치로 안전하게 제공할 수 있는 데이터로 한정함
- 데이터 품질, 활용 가능성, 법적 제한 사항을 종합 고려하여 개방 여부를 결정함

○ 비식별 조치 및 관리

- 비식별 조치는 단순 삭제가 아니라 데이터 결합 가능성까지 고려하여 재식별 위험을 최소화하는 방식으로 수행함
- 비식별 처리 후에도 지속 점검하고 외부 환경 변화에 따라 추가 조치를 검토함
- 센터는 비식별 처리 기준·절차를 마련하고 개방 전 사전 검토를 수행함

□ 인공지능(AI) 활용 데이터(신설)

○ 생성형 AI 이용 기준

- 생성형 AI 서비스에 개인정보, 민감정보, 미공개 연구자료, 내부 기밀정보를 입력하지 않음
- 교육부·대교협 「대학 AI 활용 윤리 가이드라인」을 참고하여 교육·연구·행정 분야별 활용 기준을 마련함
- 기관 차원 도입 서비스는 데이터 학습 활용 여부, 저장 위치(국외 이전 여부), 보안 수준을 사전 검토함

○ AI 학습데이터 관리

- 개인정보가 포함된 학습데이터는 가명처리를 원칙으로 하고 수집 출처·목적·보유기간을 기록함
- 개인정보보호위원회 「생성형 AI 개발·활용을 위한 개인정보 처리 안내서」(2025. 8.)의 단계별 기준(목적 설정 → 전략 수립 → 학습·개발 → 적용·관리)을 적용함

○ AI 서비스 제공 시 준수 사항

- AI 기반 서비스 제공 시 AI 사용 사실을 사전에 고지하고 생성 결과물임을 표시함(인공지능기본법)
- 백병원 의료 AI, 채용 등 고영향 AI 해당 여부를 사전 검토하고 위험관리·설명·이용자 보호 방안을 마련함
- AI를 활용한 평가·선발 등 자동화된 결정은 정보주체의 거부·설명 요구권을 보장함

○ AI 서비스 유형별 보안 기준

유형	특징	중점 보안 기준
내부 폐쇄형	교내 서버에서 내부 데이터로 추론·분석	망 분리, 접근권한 최소화, 결과물 반출 심사

외부 연계 생성형	외부 AI 모델·서비스에 입력하여 활용	입력 데이터 등급 제한(기밀·민감 입력 금지), 데이터 학습 활용 여부·저장 위치 확인, 계약상 보호조치
검색 기반 (RAG)형	교내 문서·지식베이스를 검색해 답변 생성	지식베이스 등록 자료 승인, 출처·무결성 검증, 이용자 권한에 따른 검색 범위 제한
에이전트형	AI가 도구 호출·업무 처리를 자동 수행	서비스 계정·토큰 최소 권한, 중요 작업 사람 승인, 수행 이력 기록

○ AI 고유 위협 대응

- 프롬프트 인젝션·우회 시도: 입력·출력 필터링, 정책 위반 탐지, 중요 결정은 사람이 최종 확인
- 지식베이스·학습데이터 오염: 등록 자료 출처 확인과 변경 이력 관리, 정기 무결성 점검
- 에이전트 권한 오남용: 업무별 최소 권한 부여, 외부 전송·삭제 등 고위험 작업은 사전 승인
- 외부 모델·API 공급망 위험: 도입 전 보안성 검토, API 키 안전 보관, 이용 로그 관리
- AI 결과물 오류(환각): 공식 문서·대외 발표에 활용 시 사실 확인 절차를 거침

□ 개인정보 침해 사고 대응

○ 기본 방향

- 침해 사고는 조직의 신뢰도와 법적 책임에 중대한 영향을 미치므로 사전 예방과 함께 신속하고 체계적인 대응 체계가 필수적임
- 사고 발생 시 피해 확산을 최소화하고 재발을 방지하기 위한 표준화된 사고 대응 체계를 운영함

○ 개인정보 침해 사고 유형

- 침해 사고란 개인정보가 분실, 도난, 유출, 위조·변조 또는 훼손되는 모든 사고를 의미함(2026 개정법으로 위조·변조·훼손 명시)
- 외부 침해: 해킹, 악성코드 감염, 시스템 취약점 공격 등 외부 요인에 의한 유출
- 내부 관리 부실: 접근 권한 관리 미흡, 내부자 오·남용, 실수로 인한 외부 전송 등
- 물리적 사고: 문서 분실, 저장 매체 분실, 시설 침입 등
- 위탁·외부 연계 사고: 수탁자 관리 부실, 외부 기관과의 데이터 연계 과정 유출 등
- 센터는 사고 유형을 기준으로 예방 및 대응 전략을 수립함

○ 사고 대응 절차

단계	주요 조치	기한
1. 사고 인지·보고	사고 발생 여부 확인, 관련 부서·센터·CPO 즉시 보고, 유형·발생 시점·영향 범위 1차 파악	즉시
2. 초기 대응	시스템 접근 차단, 계정 잠금, 네트워크 분리 등 추가 유출·피해 확산 방지	즉시
3. 유출 가능성 통지	유출이 확정되지 않았더라도 가능성을 알게 된 경우 정보주체에게 통지	72시간 이내
4. 유출 통지·신고	유출 확인 시 정보주체 통지, 신고 대상이면 개인정보보호위원회 또는 KISA 신고	72시간 이내
5. 조사·분석	원인, 침해 범위, 유출 항목 상세 분석, 필요 시 정보보안 부서·외부 전문기관 협력	사고 후
6. 복구·개선	시스템 복구, 취약점 보완, 관리 절차 개선, 재발 방지 대책 수립	사고 후

- 센터는 사고 대응 전 과정에서 조정·관리 역할을 수행함

○ 통지 및 보고

- 정보주체 통지 항목: 유출 등이 된 항목, 시점·경위, 피해 최소화 방법, 대응 조치·피해 구제 절차, 손해배상·분쟁조정 청구 방법, 담당 부서·연락처
- 신고 대상: 1천명 이상 유출, 민감정보·고유식별정보 유출, 해킹 등 불법 접근에 의한 유출
- 가능성 통지 후 72시간 내 실제 유출이 확인되면 유출 통지로 갈음하고, 유출이 아닌 것으로 확인되면 그 사실을 즉시 통지함
- 보고 내용에는 사고 개요, 원인, 조치 내용, 재발 방지 대책을 포함함
- 센터는 통지·보고 절차와 서식을 표준화하여 사고 시 혼선 없이 대응할 수 있도록 지원함
- ※ 개정법상 유출 신고 근거는 제34조 제4항으로 이동하였으므로 내부 문서 인용을 수정

□ 점검 및 감사

○ 자체 점검

- 개인정보 보호 및 데이터 관리 수준을 유지·개선하기 위해 정기적인 자체 점검을 실시함
- 내부관리계획, 데이터 처리 절차, 보호조치 이행 여부를 대상으로 연간 계획에 따라 수행하며, 신규 사업·대규모·고위험 처리 시 수시 점검을 추가함
- 미흡 사항은 개선계획을 수립하여 이행 여부를 관리하고, 센터는 결과를 종합·분석하여 전사적 개선 과제로 연계함

○ 외부 감사 및 평가 대응

- 외부 감사와 감독기관 점검에 대비하여 관련 문서, 기록, 이행 내역을 체계적으로 관리함
- 공공기관 개인정보 보호수준 평가(2026년 평가 기간 2026. 9.~2027. 3., 유출 시 감점 확대)와 처리방침 평가 대상 여부를 확인하여 대비함
- 외부 감사 대응 시 센터를 중심으로 관련 부서가 협력하고, 지적 사항은 신속히 개선하며 반복 지적 방지를 위해 원인 분석과 제도 개선을 병행함
- 센터는 외부 감사 결과를 내부 정책과 가이드라인 개선에 적극 반영함

□ 운영 성과 관리

- 데이터 거버넌스 운영 수준을 확인할 수 있는 지표를 설정하고 매년 점검함

구분	지표	목표 수준
----	----	-------

교육	개인정보 보호 교육 이수율	100%
점검	자체 이행점검 실시 및 지적사항 개선율	반기 1회 / 개선율 100%
관리	데이터 등급 분류 완료 부서 비율	연차별 확대
권한	접근권한 정기 점검 및 정비율	반기 1회 / 100%
사고	침해 사고 건수 및 기한 내 통지·신고 준수율	사고 최소화 / 준수율 100%
복구	1등급 시스템 복구 훈련 실시율	연 1회 / 100%
활용	가명정보·연구데이터 사전 검토 처리 건수 및 기간	요청 후 2주 이내 회신

○ 지표 결과는 연간 운영 실적 보고에 포함하고, 미달 항목은 다음 연도 개선 과제로 반영함

□ 지속적 개선 체계

○ 법·제도 변화 반영

- 개인정보 보호법, 인공지능기본법, 공공데이터법, 국제 규범 등의 개정 동향을 상시 모니터링하여 데이터 관리 체계에 반영함
- 법·제도 모니터링 대장을 운영하여 분기별로 갱신하고, 개정 시 영향 분석 후 내부 정책·운영 절차를 개선함
- 이를 통해 법적 리스크를 사전에 차단하고 최신 기준에 부합하는 관리 체계를 유지함

○ 가이드라인 개정 절차

- 본 가이드라인은 고정된 문서가 아니라 환경 변화에 따라 지속적으로 개선되는 살아 있는 기준으로 운영함
- 개정이 필요하면 센터가 개정 사유, 주요 변경 내용, 영향 범위를 검토하여 개정안을 마련함
- 관련 부서 의견 수렴, 법적 검토, 내부 승인 절차를 거쳐 확정하고, 변경 사항은 구성원에게 공유하며 필요 시 교육·설명회를 실시함
- 지속적 개선 체계를 통해 인제대학교 데이터 거버넌스의 안정성과 유연성을 동시에 확보함

□ 기본 방향

- 데이터 보호는 개인정보 처리 기준뿐 아니라 데이터를 저장·처리하는 전산실, 서버, 네트워크 등 물리 인프라의 안정적 운영을 전제로 함
- 2025. 9. 국가정보자원관리원 화재로 정부 정보시스템 709개가 중단되었으며, 감사 결과 백업 보유 시스템이 7.6%에 그치고 복구 훈련이 장기간 미 실시된 것으로 확인됨
 - 무정전 전원장치(UPS) 배터리 이전 작업 중 전원 미차단이 원인으로 지적되어 설비 작업 관리의 중요성이 부각됨
- 본교는 전산 환경 규모에 맞게 전력·공조·소방, 설비 감시, 백업·재해복구, 외부 데이터센터 이용 기준을 마련함

□ 전산 환경 구분 및 관리

- 전산 환경 구분

구분	예시	관리 수준
중요 전산실	학사·인사·재무 등 핵심 시스템 서버실	통제구역 지정, 전력·공조 이중화, 24시간 설비 감시
데이터 분석실	의료데이터 폐쇄망 분석 공간, AI 분석 서버	통제구역 지정, 망 분리, 반입·반출 통제
부서 서버	연구실·부서 단위 서버, GPU 워크스테이션	등록 관리, 보안 점검, 중요 데이터 저장 시 전산실 이관 권고
외부 인프라	클라우드, 외부 데이터센터(코로케이션)	선정 기준 충족, 계약상 보호조치, 정기 점검

- 부서·연구실에서 운영하는 서버와 고성능 장비도 전산 자산으로 등록하여 관리 사각지대를 없앴

□ 전력·공조·소방 관리

- 전력
 - 중요 시스템은 무정전 전원장치(UPS)와 비상발전기를 갖추고, 단일 장애 지점이 없도록 전원을 이중화함
 - 랙·분전반 단위 전력 사용량과 전력 품질을 감시하고, 배전반 과열 감시로 전기 화재를 예방함
 - UPS 배터리는 교체 주기와 상태를 관리하며, 리튬이온 배터리는 화재 위험을 고려하여 별도 공간 배치와 소화 대책을 검토함
- 공조
 - 전산실은 항온항습 설비로 적정 온도·습도를 유지하고, 기준 범위를 벗어나면 즉시 경보가 발생하도록 함
 - GPU 등 고발열 장비 증설 시 냉방 용량과 전력 용량을 사전에 검토함
- 소방
 - 전산실에는 전산 장비에 적합한 가스계 소화설비와 조기 화재 감지 설비를 갖추
 - 화재·정전 등 비상대응 매뉴얼은 현장에 비치하고, 정기적으로 대응 훈련을 실시함
- 설비 작업 관리
 - 전원·배터리·배선 작업은 작업계획서 승인, 전원 차단 확인, 자격을 갖춘 업체 수행을 원칙으로 함
 - 작업 중 센터·시설 담당자가 입회하고, 작업 전후 시스템 상태와 백업 여부를 확인함

□ 설비 감시(모니터링)

- 전력·공조·환경(온도·습도·누수) 설비 상태를 실시간으로 감시하고 이상 발생 시 문자·메일 등으로 즉시 알림
- 감시 기록은 일정 기간 보관하여 장애 원인 분석과 용량 계획에 활용함
- 규모 확대 시 전력·공조·자산을 통합 관리하는 설비 통합관리 시스템(DCIM) 도입을 중장기적으로 검토함

□ 백업 및 재해복구

- 백업 원칙
 - 시스템 중요도에 따라 백업 주기와 보관 기간을 정하고, 백업 대상·방법·책임자를 명시함
 - 백업본은 3개 이상 사본, 2가지 이상 저장매체, 1개 이상 원격지 보관을 원칙으로 함
 - 백업본을 원본과 같은 전산실에 두지 않으며, 랜섬웨어 대비 변경·삭제가 불가능한 백업(불변 백업)을 확보함
 - 백업 데이터도 원본과 동일한 수준으로 암호화·접근 통제를 적용함
- 복구 목표 설정

등급	대상 예시	복구 목표시간(RTO)	데이터 손실 허용(RPO)
1등급	학사·인사·재무 핵심 시스템, 의료데이터 분석 환경	24시간 이내	1일 이내
2등급	홈페이지, 업무 지원 시스템	3일 이내	1일 이내
3등급	기타 부서 시스템, 연구 서버	7일 이내	7일 이내

※ 복구 목표는 예시이며, 시스템별 업무 영향 분석 후 확정

○ 복구 훈련

- 1등급 시스템은 연 1회 이상 실제 복구 훈련을 실시하고 결과를 기록함
- 훈련 결과 목표 시간을 충족하지 못하면 개선 계획을 수립하여 이행함

○ 업무연속성 계획

- 화재·정전·랜섬웨어 등 시나리오별 대응 절차, 비상 연락망, 대체 업무 수단을 업무연속성 계획으로 문서화함

□ 외부 데이터센터·클라우드 이용

○ 외부 인프라 선정 시 다음 기준을 검토함

평가 항목	확인 내용
보안 인증	ISMS-P, ISO/IEC 27001 등 보유 여부, 공공 클라우드는 클라우드 보안인증(CSAP) 확인
가용성	전력·공조 이중화 수준, 가용성 등급(Tier 등), 서비스수준협약(SLA)
데이터 위치	저장·처리 국가(국외 이전 해당 여부), 재위탁 여부
백업·복구	백업 제공 범위, 재해복구 체계, 복구 목표시간
보안 관리	접근 통제, 암호화, 로그 제공, 사고 통지 의무
계약 종료	데이터 반환·파기 방법 및 확인서 제공

○ 의료데이터 등 민감 데이터는 원칙적으로 교내 폐쇄망 또는 인증된 전용 환경에서 처리함

□ 구축 검증 및 자산 관리

○ 구축 검증

- 신규 전산 환경 구축 시 설계 검토, 설치 검증, 성능 시험, 장애 대응(이중화 전환) 시험을 거친 후 인수함
- 인수 시 운영 매뉴얼과 설비 운영자 교육을 함께 받도록 계약에 포함함

○ 자산 관리

- 서버·스토리지·네트워크 장비·저장매체를 자산대장으로 관리하고, 위치·담당자·보관 데이터 등급을 기록함
- 장비 폐기·반납 시 저장매체는 복구 불가능하도록 완전 삭제하거나 물리적으로 파괴하고 확인서를 보관함

○ 에너지 효율

- 전력효율지수(PUE) 측정, 그린데이터센터 인증 등 에너지 효율 관리를 중장기 과제로 검토함

□ 데이터 보안 등급 분류

○ 데이터의 중요도와 유출 시 영향에 따라 보안 등급을 분류하고, 등급별로 저장·접근·반출 기준을 차등 적용함

등급	정의	대상 예시	처리 기준
기밀	유출 시 정보주체·대학에 중대한 피해가 발생하는 데이터	의료정보 원본, 유전정보, 고유식별정보, 미공개 연구 핵심자료, 인증·보안 정보	폐쇄망 처리, 반출 금지(가명처리 후 승인 시 예외), 외부 AI 입력 금지
민감	유출 시 개인 또는 대학 업무에 피해가 발생하는 데이터	학사·성적, 인사·급여, 일반 개인정보, 내부 행정자료, 가명정보	업무망 처리, 접근권한 통제, 반출 시 승인·암호화, 외부 AI 입력 금지
공개	공개되어도 피해가 없는 데이터	공시 자료, 공공데이터 개방 자료, 익명 통계	인터넷망 처리 가능, 무결성 관리

○ 데이터 소관 부서가 등급을 지정하고 센터가 검토하며, 등급이 불명확하면 상위 등급으로 취급함

○ 등급 분류 결과는 자산대장·데이터 목록에 기록하고 연 1회 재검토함

※ 국가정보원 국가망 보안체계(N2SF)의 기밀·민감·공개(C/S/O) 등급 개념을 참고하여 본교 실정에 맞게 적용

□ 망 구조 및 접근 원칙

○ 망 구분

- 업무망, 인터넷망, 관리망(서버·장비 관리용), 폐쇄 분석망을 구분하고, 등급에 맞는 망에서 데이터를 처리함
- 관리망은 일반 업무망과 분리하고, 관리자 접속은 지정된 단말과 경로로만 허용함

○ 내부 확산 방지

- 서버 간 통신은 업무상 필요한 경로만 허용하고, 같은 관리망 안에서도 기능·등급별로 구간을 나눔
- 망 사이 자료 이동은 승인된 자료교환 절차와 시스템을 통해서만 수행하고 기록함

○ 접근 원칙(제로트러스트)

- 내부망에 있다는 이유만으로 신뢰하지 않고, 사용자·단말·접속 대상 애플리케이션을 매번 확인한 뒤 최소 권한으로 접근을 허용함
- 중요 시스템과 원격 접속에는 다중 인증을 적용함

□ 계정 및 비밀번호 관리

○ 관리자 계정·비밀번호를 서버나 파일에 평문으로 저장하지 않고, 승인된 저장소에 암호화하여 보관함

○ 여러 시스템에서 같은 비밀번호를 재사용하지 않으며, 여러 사람이 함께 쓰는 공유 계정은 원칙적으로 없앴

○ 관리자 권한은 개인별로 부여하고 사용 이력을 기록하며, 퇴직·전보 시 즉시 회수함

○ API 키·토큰·서비스 계정은 용도별로 발급하고 유효기간을 두며 소스코드·문서에 노출되지 않도록 관리함

※ 2025년 통신사 해킹 사례에서 관리자 계정 평문 저장과 계정 재사용이 내부 확산의 주요 원인으로 지적됨

□ 탐지 및 대응 체계

○ 단계별 고도화

단계	내용	시기
1단계	주요 시스템 로그 중앙 수집, 서버·단말 악성코드 방지, 이상 접속 정기 점검	단기
2단계	서버·단말 이상행위 탐지(EDR), 로그 통합 분석(SIEM)으로 연관 위협 탐지	중기
3단계	탐지 시 계정 차단·단말 격리·데이터 반출 차단이 자동 연동되는 대응 체계	장기

○ 탐지된 이상 징후는 Ⅷ장 사고 대응 절차와 연계하여 처리하고, 조치 결과를 탐지 규칙 개선에 반영함

○ 교내 역량이 부족한 영역은 외부 전문기관의 보안관제 서비스를 활용할 수 있음

□ 신규 시스템 보안성 검토

○ 개인정보 또는 기밀·민감 데이터를 처리하는 시스템·AI 서비스를 도입·변경할 때 보안성 검토를 거침

단계	주요 내용
1. 범위·자산 식별	서비스 범위, 처리 데이터와 등급, 관련 계정·외부 연계 식별
2. 위협 식별	데이터 흐름도 작성, 신뢰 경계와 공격 가능 지점, 예상 공격 시나리오 도출

3. 보안 요구사항	접근 통제, 암호화, 로그, 반출 통제 등 필요한 보호조치 정의
4. 통제 적용	요구사항을 설계·설정·계약에 반영
5. 검증	취약점 점검, 모의해킹(필요 시 레드티밍) 후 조치 완료 확인
6. 운영 점검	운영 중 정기 점검, 변경 시 재검토

- 개인정보 영향평가 대상에 해당하는 공공기관 시스템은 영향평가를 함께 이행함
- 검증은 구축 마지막 단계가 아니라 설계 단계부터 반복적으로 수행하는 것을 원칙으로 함(보안 내재화)

□ 시행 및 개정

- 본 가이드라인은 내부 승인일부터 시행함
- 시행 당시 진행 중인 데이터 처리 활동은 시행일부터 6개월 이내에 본 가이드라인에 맞게 정비함
- 개정이 필요한 경우 Ⅷ장의 개정 절차에 따라 개정하며, 개정 내용과 시행일은 구성원에게 공유함

붙임 1 2026년 주요 법·제도 개정 반영 현황

법령·지침	시행일	반영 내용	반영 위치
개인정보 보호법 개정 (법률 제21445호)	2026. 9. 11.	대표자 책임, CPO 이사회 의결·신고, 유출 가능성 72시간 통지, 과징금 10%, 과태료 상향	I , II , III, VIII
개인정보의 안전성 확보조치 기준	2025. 10. 31. (일부 2026. 10. 30.)	전체 이용자 인증·접속기록, 점검 주기 자율화, 출력·복사 안전조치, 망 분리 개선	III, IV, VI
가명정보 처리 가이드라인	2026. 3.	위험도 기반 가명처리 절차, AI 확장 목적, 비정형데이터 표본 검증	V , VII
인공지능기본법	2026. 1. 22.	AI 사용 고지·생성물 표시, 고영향 AI 검토	III, VII
인공지능 및 데이터 기반 행정 활성화에 관한 법률	2026. 8. 28.	공공부문 AI·학습데이터 품질관리(적용 여부 확인)	III
보건의료데이터 활용 가이드라인	2025. 12. 31.	IRB·DRB 연계, 공용 DRB, 사망자 데이터 기준	III, VII
의료법 개정	2026. 12. 10.	전자의무기록 열람 기록 보관	III, VI
국가연구데이터법	2027. 6. 10.	DMP 작성·연구데이터 등록 지원	III, VII
개인정보 보호 인증 의무화	2027. 7. 1.	대상 고시 확정 시 반영	추후
EU AI Act 개정 등 국제 규범	2026. 7. 이후	고위험 AI 적용 연기, 한-EU 적정성 유지, 미국 데이터 이전 규제	III, V
국가정보자원관리원 화재 감사 결과	2026. 9.	전력·소방 작업 관리, 백업·재해복구, 복구 훈련	IX
국가망 보안체계(N2SF) (참고)	-	데이터 보안 등급, 망 구조, 보안성 검토 절차	X

※ 조문 번호·시행일은 국가법령정보센터 원문 대조 후 최종 확정

붙임 2 데이터 보안 등급 분류(예시)

○ 부서별 데이터 목록을 작성할 때 참고할 수 있는 분류 예시이며, 실제 등급은 소관 부서가 지정하고 센터가 검토함

영역	데이터	등급	주요 처리 기준
학사	학적·수강·성적, 장학 정보	민감	학사 시스템 내 처리, 권한 최소화, 반출 시 승인
학사	졸업생 학위 정보(공시 범위)	공개	공시 기준 확인 후 제공
인사	인사·급여, 인사기록카드	민감	인사 시스템 내 처리, 열람 이력 관리
인사	주민등록번호 등 고유식별정보	기밀	법령 근거 확인, 암호화 저장, 별도 접근 승인
연구	연구계획서, 미공개 연구데이터	기밀	연구책임자 지정 보관, 외부 AI 입력 금지
연구	가명처리된 연구데이터	민감	추가정보 분리 보관, 승인 범위 내 활용
연구	공개 논문·공개 데이터셋	공개	출처 표시, 무결성 관리
의료	진료·검사·영상 데이터 원본	기밀	폐쇄망 처리, 반출 금지, IRB·DRB 승인 후 가명처리
산학	기업 제공 데이터, 계약 정보	기밀 또는 민감	계약상 보호조치 준수, 등급은 계약서 기준
행정	회계·계약 자료	민감	권한 통제, 보존기간 관리
행정	공공데이터 개방 대상 자료	공개	비식별 조치 및 사전 검토 후 개방
보안	계정·비밀번호, 암호키, 보안 설정	기밀	지정 저장소 보관, 접근 기록 관리

붙임 3 자체 이행점검 체크리스트

○ 반기 1회 자체 점검 시 활용하며, 점검 결과는 개선 계획과 함께 관리함

영역	점검 항목	확인
관리 체계	내부관리계획을 수립·개정하고 실제 운영에 반영하고 있는가	()
관리 체계	보호책임자·분임책임자 지정 현황이 최신인가	()
관리 체계	보호 현황을 경영진(이사회)에 보고하였는가	()
수집	수집 목적·항목이 최소 수집 원칙에 맞는가	()
수집	동의서에 목적·항목·보유기간·제공 여부가 명시되어 있는가	()
수집	민감정보·고유식별정보에 별도 동의 또는 법령 근거가 있는가	()
보관	데이터별 보유기간이 설정되고 준수되고 있는가	()
보관	보유기간이 지난 데이터가 지체 없이 파기되었는가	()
보관	파기 기록(일자·대상·방법·확인자)이 남아 있는가	()
접근	접근권한이 최소 권한으로 부여되고 정기 점검되었는가	()
접근	인사이동·퇴직자 권한이 즉시 회수되었는가	()
접근	관리자 계정·비밀번호가 평문으로 저장되어 있지 않은가	()
접근	공유 계정이 사용되고 있지 않은가	()
기술	고유식별정보·비밀번호·생체정보가 암호화되어 있는가	()
기술	외부 접속에 다중 인증이 적용되어 있는가	()
기술	접속기록이 기준 기간 이상 보관되고 정기 점검되는가	()
기술	보안 프로그램·보안 패치가 최신 상태인가	()
제공	제3자 제공·위탁 내역이 기록·공개되고 있는가	()
제공	수탁자 관리·감독(교육·점검)이 이루어졌는가	()
제공	국외 이전 현황과 적법 근거가 관리되고 있는가	()
연구	연구데이터가 IRB 승인 범위 내에서 처리되고 있는가	()
연구	가명정보 처리 기록과 추가정보 분리 보관이 이행되는가	()
AI	생성형 AI에 기밀·민감 데이터가 입력되지 않았는가	()
AI	AI 서비스 이용 고지·생성물 표시 기준이 지켜지는가	()
물리	통제구역 출입 기록과 권한이 정기 점검되었는가	()
물리	저장매체 반입·반출이 승인·기록되고 있는가	()
인프라	전력·공조·환경 감시와 경보가 정상 작동하는가	()
인프라	설비 작업 시 작업계획 승인과 입회가 이루어졌는가	()
복구	백업이 주기대로 수행되고 원격지 사본이 있는가	()
복구	복구 훈련을 실시하고 목표 시간을 충족하였는가	()
사고	사고 대응 절차·비상 연락망이 최신이며 훈련되었는가	()
교육	대상별 교육이 계획대로 실시되고 이수율이 관리되는가	()

붙임 4 단계별 이행 로드맵

시기	과제	주요 내용	담당
2026. 10.	안전조치 기준 대응	접근권한·인증·접속기록 정비(2026. 10. 30. 시행 대비)	정보보안, 센터
2026. 10.	사고 대응 절차 개정	유출 가능성 72시간 통지 절차·서식 반영	센터
2026. 11.	CPO 대상 여부 확인	학교법인·백병원 기준 확인 후 이사회 의결·신고 준비	보호책임 부서, 법무
2026. 12.	가이드라인 확정	내부 의견 수렴·법적 검토·승인, 구성원 공유	센터
2027. 상반기	데이터 등급 분류	부서별 데이터 목록 작성 및 등급 지정	전 부서, 센터
2027. 상반기	백업·복구 체계 정비	업무 영향 분석, 원격지·불변 백업 확보, 복구 훈련	정보화, 센터
2027. 상반기	보안성 검토 절차 도입	신규 시스템·AI 서비스 사전 검토 서식 운영	센터, 정보보안
2027. 하반기	탐지·대응 강화	로그 통합 수집, 이상행위 탐지 도입 검토	정보보안
2027. 하반기	인증·평가 대응	ISMS-P 의무 대상 여부 확인, 보호수준·처리방침 평가 대비	센터
2027~	연구데이터 지원	DMP 지원 체계, 연구데이터 등록 절차 마련	연구지원, 센터

붙임 5 표준 서식 목록

○ 본 가이드라인 시행을 위해 마련·운영할 서식이며, 서식은 센터가 제공하고 정기적으로 갱신함

구분	서식	용도
수집	개인정보 수집·이용 동의서(일반/연구/의료)	목적·항목·보유기간·제공 여부 고지 및 동의
수집	민감정보·고유식별정보 별도 동의서	법령 근거 또는 별도 동의 확보
제공	제3자 제공 검토서, 제공 대장	제공 근거·범위 검토 및 이력 관리
위탁	개인정보 처리 위탁 계약 표준 조항, 수탁자 점검표	수탁자 관리·감독
국외	국외 이전 검토서, 이전 현황 대장	요건 확인 및 현황 관리
연구	가명처리 계획서·적정성 검토서, 처리 기록부	가명정보 처리 절차 이행
연구	데이터 제공 신청서(연구자용), 결과물 반출 심사서	분석 환경 이용·반출 통제
보안	접근권한 신청·변경·회수 신청서, 권한 점검표	권한 관리
보안	보안성 검토 요청서(신규 시스템·AI 서비스)	도입 전 위협·요구사항 검토
파기	파기 계획서·파기 확인서	파기 절차 및 기록
사고	사고 발생 보고서, 정보주체 통지문, 감독기관 신고서	사고 대응 및 통지·신고
점검	자체 이행점검표, 개선 조치 이행 결과서	정기 점검 및 개선 관리
인프라	설비 작업 계획·승인서, 백업·복구 훈련 결과서	인프라 작업 및 복구 훈련 기록

붙임 6 용어 및 약어

용어·약어	설명
CPO	개인정보 보호책임자(Chief Privacy Officer). 개인정보 보호 업무를 총괄하는 책임자
IRB	기관생명윤리위원회(Institutional Review Board). 인간대상연구의 윤리적·과학적 타당성 심의
DRB	데이터심의위원회(Data Review Board). 보건의료데이터 활용의 적정성 심의
DMP	데이터관리계획(Data Management Plan). 연구데이터의 수집·보관·공개 계획
가명처리	추가 정보 없이는 특정 개인을 알아볼 수 없도록 처리하는 것
비식별 조치	개인을 알아볼 수 없도록 데이터를 처리하는 일련의 조치
ISMS-P	정보보호 및 개인정보보호 관리체계 인증
CSAP	클라우드 보안인증. 공공부문 클라우드 서비스 보안 인증
RTO / RPO	복구 목표시간 / 데이터 손실 허용시간. 장애 시 복구 목표를 정하는 지표
불변 백업	일정 기간 변경·삭제할 수 없도록 보호된 백업. 랜섬웨어 대응 수단
UPS	무정전 전원공급장치. 정전 시 전원을 일정 시간 유지하는 설비
DCIM	데이터센터 통합관리 시스템. 전력·공조·자산을 통합 감시·관리
EDR / SIEM	단말·서버 이상행위 탐지 / 로그 통합 분석 체계
제로트러스트	내부망이라도 신뢰하지 않고 접속할 때마다 사용자·단말·권한을 확인하는 보안 원칙
RAG	검색 증강 생성(Retrieval-Augmented Generation). 내부 자료를 검색해 답변을 생성하는 AI 방식
프롬프트 인젝션	AI에 악의적 지시를 주입해 정책을 우회하거나 정보를 빼내는 공격
고영향 AI	생명·안전·기본권에 중대한 영향을 미칠 수 있는 인공지능(인공지능기본법)
N2SF	국가망 보안체계. 데이터 등급에 따라 보안 통제를 차등 적용하는 국가 보안 체계
GDPR	EU 일반개인정보보호법. EU 거주자 개인정보 처리에 적용
SCC	표준계약조항. 국외 이전 시 적용하는 개인정보 보호 계약 조항

붙임 7 관련 법령 및 참고자료

구분	자료명	발행·소관
법률	개인정보 보호법 및 시행령	개인정보보호위원회
고시	개인정보의 안전성 확보조치 기준 및 안내서	개인정보보호위원회
지침	가명정보 처리 가이드라인	개인정보보호위원회
안내서	생성형 AI 개발·활용을 위한 개인정보 처리 안내서	개인정보보호위원회
법률	인공지능 발전과 신뢰 기반 조성 등에 관한 기본법 및 시행령	과학기술정보통신부
법률	인공지능 및 데이터 기반 행정 활성화에 관한 법률	행정안전부
법률	공공데이터의 제공 및 이용 활성화에 관한 법률	행정안전부
법률	데이터 산업진흥 및 이용촉진에 관한 기본법	과학기술정보통신부
법률	생명윤리 및 안전에 관한 법률	보건복지부
지침	보건의료데이터 활용 가이드라인	보건복지부
법률	국가연구데이터 관리 및 활용 촉진에 관한 법률	과학기술정보통신부
지침	대학 AI 활용 윤리 가이드라인	교육부·한국대학교육협의회
참고	국가망 보안체계(N2SF) 관련 자료	국가정보원
국외	EU GDPR, AI Act, Data Act, EHDS 규정	EU 집행위원회
국외	미국 대량 민감데이터 이전 제한 규칙, NIH 데이터 보안 요건	미국 법무부·NIH

※ 법령 원문은 국가법령정보센터(law.go.kr), 지침·안내서는 개인정보보호위원회(pipc.go.kr) 등에서 최신본 확인

붙임 8 확정 전 검토 필요 사항

□ 제도·법령 확인

- CPO 이사회 의결·신고 대상 판단 단위(학교법인 또는 대학·병원 각각) 및 부산백병원 적용 여부
- 본교 재학생 수 확인(재학생 2만명 이상 대학 요건, 교육 분야 전송요구권 대상 여부)
- 공공AI법 및 공공기관 개인정보 보호수준 평가의 사립대학 적용 여부
- ISMS-P 인증 의무 대상 고시 내용(2027. 7. 1. 시행)
- 조문 번호·시행일의 국가법령정보센터 원문 대조

□ 내부 확정 사항

- 시행일 및 승인 절차, 관련 학내 규정과의 정합성 검토
- 데이터 유형별 표준 보관 기간표 작성
- 시스템별 복구 목표시간(RTO)·데이터 손실 허용(RPO) 확정을 위한 업무 영향 분석
- 전산실·분석실 보호구역 지정 및 부서별 데이터 등급 분류 목록 작성
- 탐지·대응 체계 단계별 예산 및 외부 보안관제 활용 여부
- 표준 서식(붙임 5) 제작 일정 및 담당 부서

※ 붙임 3 체크리스트의 확인란은 점검 시 작성하는 칸이며, 그 밖에 비워 둔 항목은 없음